

# INO Security Audit V

More was genuinely fixed this round than in any previous one, and the review process itself improved. But the two things blocking a Play submission are unchanged, and account deletion broke for the fourth consecutive round — this time as a side effect of fixing a Medium.

4 Sep 2026    6390fdf → d186d06 · 5 commits    553 of 553 tests pass

## OVERALL SCORE

6/10

unchanged from 6/10 · 4 at pass 1

### Closest yet, still blocked

Roughly eighteen fixes verified.  
Two Play blockers untouched, one  
Critical newly introduced.

|                     |                        |      |
|---------------------|------------------------|------|
| Auth & session      | <div><div></div></div> | 7 —  |
| Backend & RLS       | <div><div></div></div> | 6 ▲1 |
| Crypto & local data | <div><div></div></div> | 6 ▲1 |
| Privacy & Play      | <div><div></div></div> | 6 ▲1 |
| Sharing             | <div><div></div></div> | 5 ▼1 |
| Platform & build    | <div><div></div></div> | 5 ▼1 |

## What genuinely got fixed

Every Critical and High from the last report verifies as closed, and the privacy surface finally moved after three rounds of standing still.

- **The vault double-encryption Critical is properly dead.** The sealed state is now a real serialised field rather than something re-derived at write time, a hydrated-while-locked flag is set on the single load path, and three independent guards stand between any caller and a reseal. Backed by tests using real cryptography with byte-exact disk comparison.
- **The web account-deletion portal is real.** A genuine two-step form, an OTP verified against the auth service, and the deletion invoked under the user's own token — not a service key. This closes a blocker that stood through four audits.
- **Unauthenticated vault-document deletion is closed on both axes** — an explicit null-caller check placed before the comparison, and a real revoke from public. The same treatment was correctly extended to the sibling function.

- **Both deployment blockers are gone.** Duplicate migration timestamps renamed with no ordering regression, and the quota trigger now reads the size from metadata on both paths so uploads are no longer rejected.
- **The in-app policy gained named processors, statutory rights and a grievance contact** in all three languages, and finally carries a September date.
- **Voice defaults to on-device, the reminder scheduler honours the notifications toggle**, and the data export no longer leaks the raw ID beside its own mask.
- **The device-token handover is fixed properly**, via a definer function that is actually wired into the app rather than left orphaned — so a resold phone no longer receives the previous owner's notifications.
- **Lockout decay, the poisoned-row sweep, co-owner vault preservation, and backup extraction rules** all landed.

### You fixed the review process, and it worked

Last round I flagged that the Apple association file contained the literal string `TEAMID` while its test asserted `contains('com.ino.app')` — a substring match the placeholder satisfied. Both halves are now fixed:

```
apple-app-site-association  "appID": "9JA6MVCD82.com.ino.app"

share_security_hardening_test.dart
  expect(appIDRegex.hasMatch(appID), isTrue);
  expect(appID, equals(expectedAppId));      // exact, not substring
```

A new route also validates the team ID against a strict pattern and explicitly rejects placeholder values. That is the meta-feedback being acted on, not just the finding — and it is the single most encouraging thing in this report.

The pattern persists elsewhere, though. Several backend tests still read migration files and assert `contains('RAISE EXCEPTION')`, which passes on any raise anywhere in a 17KB file and cannot detect a single defect below.

# Critical

C1

## A committed secret makes both rate limits decorative

CRITICAL

NEW

verified

supabase/functions/share/index.ts:122-123 · share-frontend/lib/client-ip.ts:8-9

The proxy-forwarding scheme added this round is sound engineering — the web routes now forward the real visitor IP, fixing the "whole site shares one bucket" problem. But the shared secret authenticating it falls back to a literal string when the environment variable is unset, and that string is committed to the repository in both the edge function and the frontend.

The variable is set nowhere I can find: not in the example environment file, not in the deployment README, not in CI, not in any Supabase secrets command. So production almost certainly runs on the committed value. Anyone who reads the repo can send that token with a forged IP header, rotating it each request, and land in a fresh bucket every time — nullifying both the sixty-per-minute limit and the five-strike password lockout. The lockout is keyed only on IP plus share, so there is no fallback protection: a password-protected share can be brute-forced at wire speed, bounded only by bcrypt.

**Fix** Remove the fallback entirely and fail closed when the variable is absent. Rotate the string, since it is now public in git history. Set it in both the Supabase function secrets and the Vercel environment. A second hardcoded fallback for the publishable key sits nearby and should go the same way.

# High

H1

## Account deletion is broken again — fourth consecutive round HIGH

NEW verified

supabase/migrations/20260906020000\_phase7\_critical\_remediations.sql:334

The rewrite to preserve co-owners' vaults — which I raised last time as a Medium — introduced a reference to a column that does not exist. The successor query orders by `joined_at`, but the members table has `created_at`. I grepped the entire migration tree: `joined_at` appears exactly once, on the line that uses it.

Because the database only syntax-checks function bodies, the migration applies cleanly and fails at runtime. The moment a user who owns a family vault taps Delete Account, the query is planned, throws, and rolls back everything the function had already deleted. Right-to-erasure becomes unavailable for a large share of users, with an opaque database error surfaced to them.

A second defect sits in the same expression: the ordering sorts a co-owner below an editor, so once the column is fixed a vault with both would be handed to the wrong person.

**Fix** Change to `created_at` and rank `owner` first. Then delete a test account that owns a vault and confirm the auth user is gone — the check that would have caught this in all four rounds.

H2

## "Forgot passphrase" is now permanently unreachable HIGH NEW verified

password\_vault\_screen.dart:158 · vault\_passphrase\_sheet.dart:175

The corruption fix works, but the guard is drawn wider than the threat. The gate that opens the passphrase sheet returns early when the vault is unlocked, so the sheet — and the "Forgot passphrase" button on it — only ever appears when the vault is locked. The new guard refuses to proceed unless the vault is unlocked.

So every reachable press returns "Please unlock the vault first", which is impossible, because forgetting the passphrase is the premise. There is no re-key path and no way to start over. This is better than the previous behaviour, which silently destroyed the server rows — nothing is corrupted now — but a user who genuinely forgets their passphrase still ends up with a permanently inaccessible vault, just by a different route.

**Fix** Allow the reset when the vault is empty, and when sealed entries exist offer an explicit "destroy the vault and start over" flow rather than a dead end.

H3

### Creating a reminder fabricates a consent record **HIGH** verified

`add_reminder_sheet.dart:147` · `push_service.dart:235-236`

Unchanged across three rounds and now the most serious remaining privacy exposure. Turning notifications off deletes the push token. Creating any reminder then calls the permission request unconditionally, with no check of that setting — which re-registers the token *and* writes a consent row recording that the user opted in to push notifications.

So a user withdraws consent, creates a reminder, and the app silently re-subscribes them while filing an audit record asserting they agreed. Under the DPDP Act that is worse than simply ignoring the toggle, because the consent trail is now affirmatively wrong.

H4

### Raw ID numbers still sit in unencrypted preferences **HIGH** verified

`document_repository.dart:115-116` · `document.dart:95,98` · `shared_prefs_cache.dart:19`

The export was sanitised this round, but the on-device cache was not. Every document is serialised with its raw record number and the full extraction envelope — number, date of birth, gender, name, father's name — and written to plain preferences with no encryption layer.

Backup is now disabled and extraction rules exist, so this needs root or forensic access rather than a backup pull, which is why I rate it High rather than Critical. The notable part is that the app already ships an encrypted store and simply does not use it on this path.

H5

### The account-deletion endpoint can be used to mail-bomb any address

**HIGH** **NEW** verified

`share-frontend/app/api/account/delete-request/route.ts:10`

The new deletion route computes the visitor IP on its first line and never uses it again — the only other reference is the import. There is no throttle, no captcha and no per-address counter, so the route will relay unlimited one-time-password emails for any address anyone supplies, burning the project's email quota and harassing the target. The unused variable suggests a limiter was intended and dropped.

H6

The CI signing gate checks the wrong thing

LATENT

verified

.github/workflows/build-apk.yml:71

A gate was added so the workflow no longer publishes unconditionally, which is why nothing is being published today. But it tests only whether the signing secrets *exist* — the workflow never decodes a keystore and never writes the properties file the build reads, and the build still falls back to debug signing with a warning.

So the day anyone adds that secret, the gate opens and a debug-signed APK publishes to a public release marked latest, with body text that says "Debug-signed CI build". The six third-party actions holding write access are still on floating tags.

## Play submission blockers

Neither has moved in five rounds, and both are outside the code as much as in it.

| BLOCKER                                                                                                                                                                                                                                                                                                                                 | STATE     |
|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------|
| <b>No legal URL that resolves.</b> The host contradiction is now five-way and this round made it worse: the in-app policy now prints <code>share.inoapp.com/privacy</code> to users in all three languages, as unclickable text, while the README still records the documented host as non-resolving and names a different one as live. | Regressed |
| <b>The published legal pages ship</b> <code>noindex, nofollow</code> . Set site-wide in the layout, and neither the privacy page nor the deletion page overrides it — so the two URLs Play must reach are marked not to be indexed.                                                                                                     | Unchanged |

## Also open

| AREA    | ISSUE                                                                                                                                                                                                                | SEVERITY |
|---------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------|
| Backend | The invite function lost its revoke to a drop-and-recreate for the second round running, and the existence oracle survives — the target's user id is still written into a row the calling admin reads straight back. | Medium   |

|          |                                                                                                                                                                                                                                                                                                |        |
|----------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------|
| Backend  | A function that alters the password-vault table and rewrites its policies is granted to every signed-in user, where its siblings are service-role only. Repeated calls take exclusive locks on the most sensitive table in the product.                                                        | Medium |
| Backend  | IP hashing is unsalted, so the values are trivially reversible, and there is still no purge job. Three plaintext fallback paths in the edge function write raw addresses into the column the migration claims is hashed.                                                                       | Medium |
| Backend  | A stale bootstrap script in the repo would, if pasted, restore the world-readable wallets policy and re-arm the exact regression this round prevented.                                                                                                                                         | Medium |
| Platform | The backup rules exclude only the root domain. Android walks the file, database, preferences and device-protected domains independently, so device-to-device transfer — the one path backup-disabling does not cover — still carries secure storage, databases and the offline document cache. | Medium |
| Sharing  | Received documents are still written to the temp directory and never deleted at all three sites, while the sibling view-once screen does clean up correctly.                                                                                                                                   | Medium |
| Sharing  | The PDF worker still loads from a third-party CDN into the page that renders decrypted documents, and the policy still permits it alongside inline and eval.                                                                                                                                   | Medium |
| Sharing  | The unlock token is still signed with the service-role key and bound only to the share and an expiry, so revoking a password leaves issued tokens valid for an hour.                                                                                                                           | Medium |
| Crypto   | Sealing can still fall through to writing plaintext if the vault locks mid-write, and four screens drop full decrypted document bodies at the temp root where nothing cleans them.                                                                                                             | Medium |
| Crypto   | A deleted account's offline library and its encryption key now outlive the account — the over-broad purge was unwired without adding a targeted one.                                                                                                                                           | Medium |
| Auth     | The two-factor screen still has no back-button guard, sign-out still disables the app lock for the next user, and removing an account still revokes nothing server-side. Three items now untouched across five rounds.                                                                         | Medium |

|         |                                                                                                                                                                                                                                                                     |        |
|---------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------|
| Privacy | The export still covers roughly three of fifteen data domains while the policy claims it covers everything; the policy's own data table still omits about fourteen collected categories; retention is stated as 90 days, coded as 30, and never actually scheduled. | Medium |
| Privacy | The 18-plus attestation is still hardcoded English on both sign-up paths, pointing at in-app terms that contain no age clause, and the consent record does not capture the attestation itself.                                                                      | Medium |
| iOS     | Voice navigation is now disabled outright on iOS by an early return, on top of the Podfile still compiling out the microphone permission the app requests.                                                                                                          | Medium |

---

## Why the score held at 6

Roughly eighteen distinct fixes verified this round — more than any previous one — and the fix quality is visibly higher: policies dropped by their real generated names, a definer function actually wired into the app rather than left orphaned, guards placed before comparisons rather than after, and a test rewritten from a substring check to an exact assertion because I asked for it.

The score does not move because the two things that decide whether you can submit are exactly where they were five rounds ago, and one of them regressed by shipping a non-resolving host into the app's own privacy screen. Alongside that, the round introduced a Critical that nullifies its own headline feature, and broke account deletion for the fourth consecutive time — this time while fixing a Medium I had raised.

That last point is the pattern worth naming. Account deletion has now failed with wrong table names, wrong column names, a working version, and now a wrong column introduced by an enhancement. Each fix was correct about the thing it targeted and wrong about something adjacent. The missing step is the same every time: nobody has yet deleted a test account and confirmed the user is gone.

---

## What to do next

- 1 **Delete the hardcoded proxy secret and fail closed without it**  
Then rotate it and set it in both environments. Until then the rate limit and the password lockout are decorative.
-



- 2 **Change `joined_at` to `created_at` and rank owners first**  
One word plus one ordering clause. Then actually delete a test account that owns a vault.
- 3 **Buy and point one domain, then reconcile every reference in a single pass**  
Eleven files name a host. Remove the site-wide noindex from the legal pages. These two together are the whole submission blocker.
- 4 **Gate the reminder sheet's permission request on the notifications setting**  
And stop writing a consent row when the user has withdrawn consent. This is the worst remaining compliance exposure.
- 5 **Rate-limit the deletion OTP endpoint**  
The IP is already computed on line 10 and thrown away.
- 6 **Give "Forgot passphrase" a real path**  
Allow it on an empty vault, and offer an explicit destroy-and-restart when sealed entries exist.
- 7 **Move the document cache onto the encrypted store you already ship**  
And enumerate every domain in the backup extraction rules rather than just root.

Items 1, 2, 4 and 5 are small and would put this at 7. Item 3 is the difference between a submission that gets reviewed and one that is rejected before anyone opens the app — and most of it is domain and hosting work, not code.

Method: four parallel re-audits covering backend and row-level security, auth and session, cryptography and local data, sharing and platform, and privacy and Play compliance. Every Critical and High was independently re-read in the code before inclusion, with several agent claims checked against the defining schema — one previously-reported High was withdrawn on that basis after the audit trail showed it was never live. The Android build was verified by running the manifest merger, the changed surface was confirmed by walking the commit history, and the full test suite was run at 553 of 553 passing. No files were modified during this audit.